

25COP928

Professionalism, Ethics and Cyber Security

Data Privacy

Dr Parisa Derakhshan

Email p.derakhshan@lboro.ac.uk

News

- Gambling firms shared data with Facebook (Feb 2025) ([Link](#))
- OpenAI faces data-breach claims (Feb 2025)([Link](#))
- TEMU app privacy concerns (2024) ([Link 1](#), [Link 2](#))
- EU probes Google AI over privacy (2024) ([Link](#))
- Meta, TikTok and other social media CEOs grilled over child safety (2024) ([Link](#))
- Oracle Health patient data breach (2026) ([Link](#))



Objectives

Understanding Data Privacy

- Why data privacy matters and how it links to ethics.

Learning from Real-World Cases

- Ethical issues shown through real cases.

Ethical Decision-Making in Practice

- Making responsible and ethical decisions with personal data.

Outlines

- What is data privacy ?
- What is personal data ?
- Data privacy issues
- Data protection laws and regulations
 - Data protection law (DPA 1998, GDPR & DPA 2018)

Data privacy

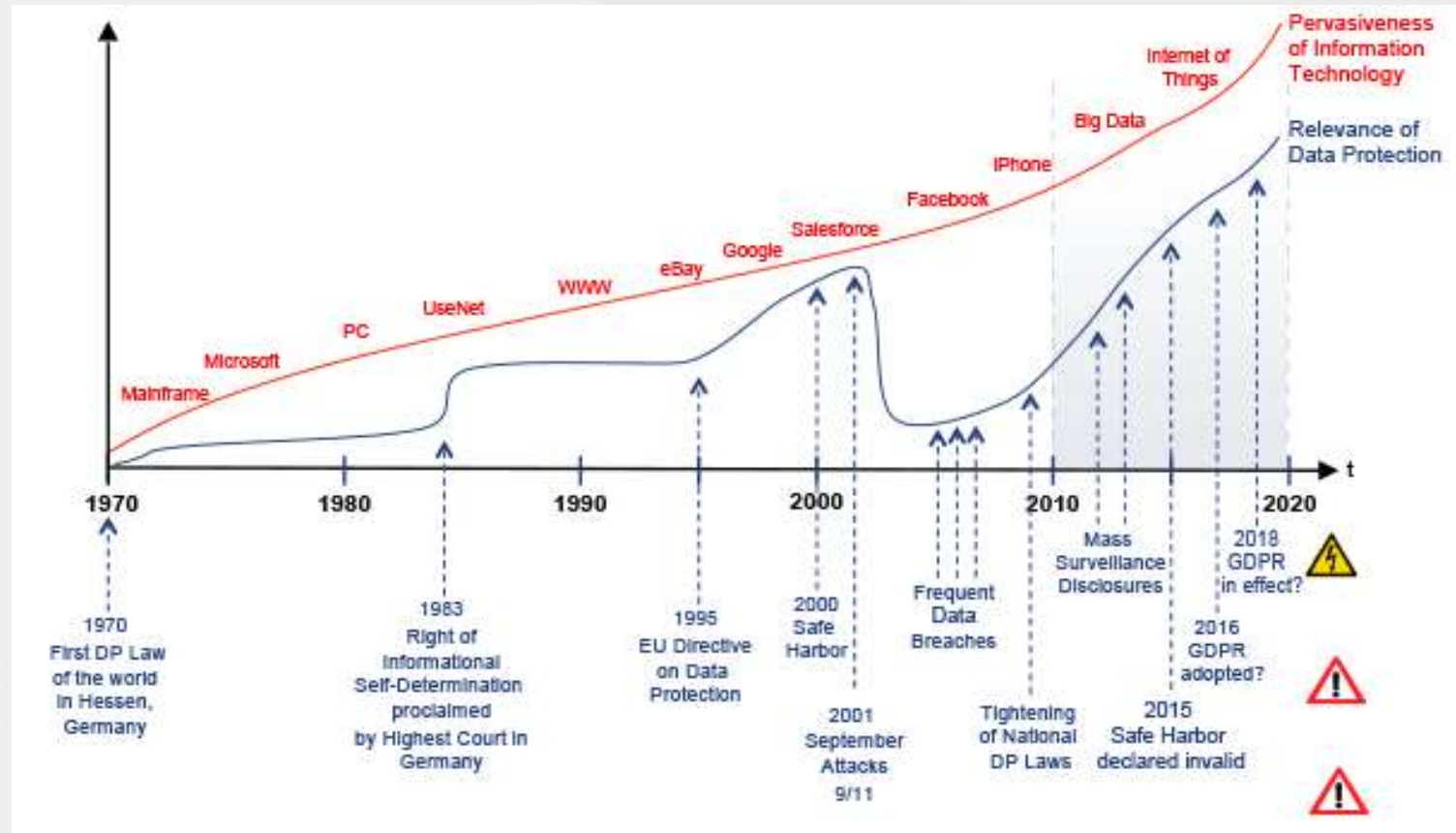
Data privacy is about protecting personal information.

This includes personal data such as:

- Medical and health records
- Financial information
- Criminal and legal records
- Political information
- Business and online data



Data privacy history



[A brief history of the GDPR](#)



Data privacy challenges

Ability of individuals to exert control over their “personal” information versus the need of authorities and organisations to process personal information to meet their goals and/or provide products and services

- Need for data protection law to balance these needs
- The aim of data protection law is to control how personal data is collected, used, and shared

PII: Personally identifiable information

Any information about an individual maintained by an organisation (NIST).

Includes:

- (1) Information that can identify or trace an individual's identity (e.g. name, date of birth, biometric records).
- (2) Information that is linked or linkable to an individual (e.g. medical, educational, financial, and employment information).

[Guide to Protecting the Confidentiality of Personally Identifiable Information \(PII\)](#)

Importance of data protection

5min Activity

- 👤 Which organisations have your data?
- 📁 What type of information do they hold?
- ✉️ Are they contacting you at the moment?
- ? Why do you think that is?



Misuse and unauthorised access to information

- Who could access this information?
- How accurate was the information?
- Could it be easily copied?
- Is it possible to store information about a person without the individual's knowledge or permission?
- Was a record kept of any changes made to information?

Data privacy issues

- Trust between customers and businesses
- New laws and regulations
- Employee training, education, and awareness
- Securing cloud-based data
- Managing third-party data risks

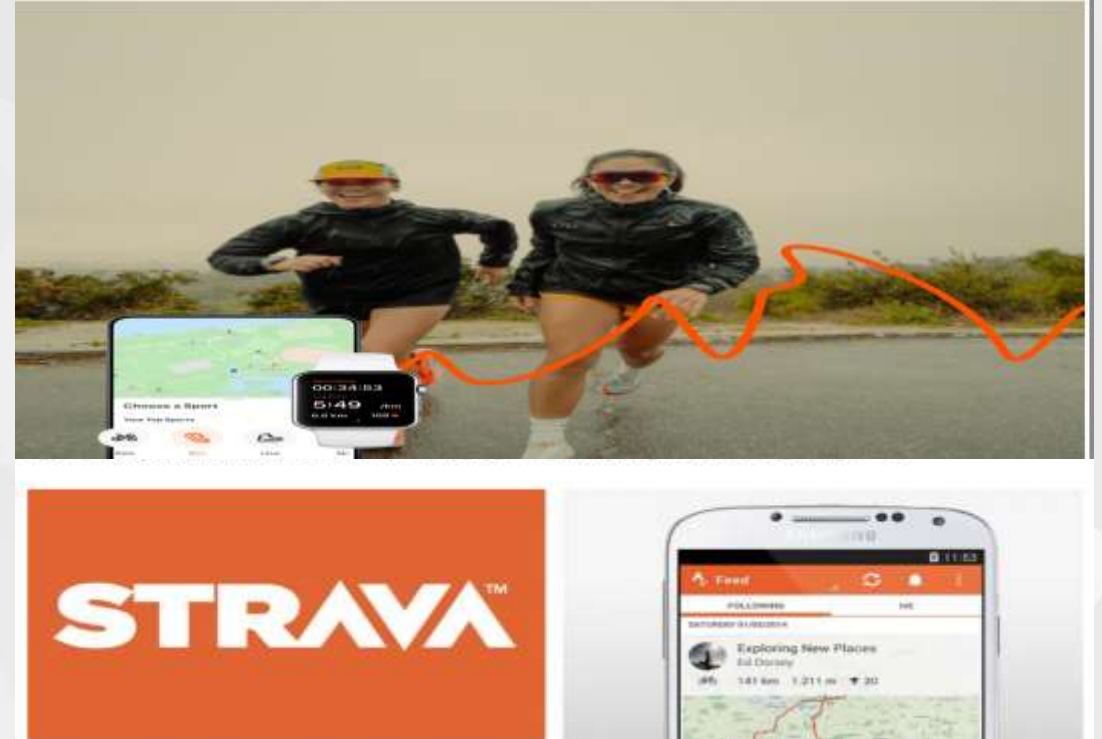


Privacy issue examples

Strava user privacy

- Users shared GPS data for fitness tracking
- Strava released a public activity heatmap
- Aggregated data revealed sensitive locations (e.g. military bases)
- Users did not expect this use of their data

How a Fitness App Revealed Secret Military Bases



[Fitness app Strava exposes the location of military bases](#)

Telegram user privacy

- The Russian-born billionaire co-founder of Telegram claimed that Ukrainian users' data was safe.
- However, Moxie Marlinspike, creator of Signal and the encryption used by WhatsApp, warned that many users mistakenly believe Telegram is fully encrypted. He explained that, by default, Telegram stores messages in the cloud with readable copies of users' messages.



NHS Scotland's Covid Status app

May 2021

The ICO issued guidance on how **Covid-status certification apps** must comply with data protection law.

Late September 2021

The ICO received full details of the **NHS Scotland Covid Status app** only **three days before mandatory checks began**.

ICO concerns and outcome

The app planned to share users' images and passport details with a third-party provider and was launched before privacy issues were resolved. After an investigation, the ICO reprimanded NHS National Services Scotland for **unclear and overly complex privacy information**.



<https://www.bbc.co.uk/news/uk-scotland-60521934>

TikTok privacy policy (1/2)

- TikTok collects lot of data
- Security vulnerabilities within the app

What Information We Collect

We collect your information in three ways: [Information You Provide](#) → , [Automatically Collected Information](#) → , and [Information From Other Sources](#) → . More detail is provided below.



<https://www.tiktok.com/legal/page/eea/privacy-policy/en>

TikTok privacy policy (2/2)

- TikTok Data sharing policy
- Lack of transparency

- **Advertising, Measurement and Other Partners.** Advertisers, measurement and other partners share information with us about you and the actions you have taken outside of the Platform, such as your activities on other websites and apps or in stores, including the products or services you purchased, online or in person. These partners also share information with us, such as mobile identifiers for advertising, hashed email addresses and phone numbers, and cookie identifiers, which we use to help match you and your actions outside of the Platform with your TikTok account. Some of our advertisers and other partners enable us to collect similar information directly from their website or app by integrating our **TikTok Advertiser Tools** ↗ (such as TikTok Pixel).

<https://www.tiktok.com/legal/page/eea/privacy-policy/en>

More data collected than expected

Technical Information. We collect certain device and network connection information when you access the Platform. This information includes your device model, operating system, keystroke patterns or rhythms, IP address, and system language. We also collect service-related, diagnostic, and performance information, including crash reports and performance logs. We automatically assign you a device ID and user ID. Where you log-in from multiple devices, we use information such as your device ID and user ID to identify your activity across devices to give you a seamless log-in experience and for security purposes.

.....

Personal privacy in online / digital age

Evidence from UK consumers (ODI Survey, 2018)

- **Age differences:** Younger adults are generally more comfortable sharing personal data than older generations.
- **Trusting and knowing organisations:** People are more willing to share personal information with organisations they trust and are familiar with, with healthcare organisations being among the most trusted.
- **Willingness to trade data for benefits:** Consumers are often prepared to share personal data when there is a clear benefit to themselves or to society.
- **Need for better data understanding:** Many consumers lack strong data skills, meaning organisations must clearly explain how personal data is collected, used, and shared.

<https://theodi.org/article/odi-survey-reveals-british-consumer-attitudes-to-sharing-personal-data/>

Data Protection law (UK)

The purpose of the Data Protection Act (DPA) 1998:

- Introduced to regulate how personal information is collected, used, and stored, and to **protect individuals' rights**.
- Similar data protection laws were introduced across other **European Union countries**, recognising that personal data is often processed across national borders.

Data protection law (DPA) 2018 – 8 principals

- Principle 1: **Fair and lawful processing**
- Principle 2: **Purpose limitation** – data used only for specified purposes
- Principle 3: **Data minimisation** – only the necessary amount of data held
- Principle 4: **Accuracy** – data kept accurate and up to date
- Principle 5: **Retention** – data not kept longer than necessary
- Principle 6: **Rights of individuals**
 - Subject access requests
 - Protection from damage or distress
 - Preventing direct marketing
- Principle 7: **Information security** – data kept secure
- Principle 8: **International transfers** – sending data outside the EEA

Data protection law (DPA) - key elements

- **Data subject**

To be informed about how their data is processed and decisions are made, to request correction or deletion, to stop processing, and to claim compensation for misuse.

- **Data controller**

The person or organisation that decides the purpose and how personal data is processed, either alone or jointly with others.

- **Data processor**

A person or organisation (not an employee of the data controller) that processes personal data on behalf of the data controller.

DPA limitations

- **Limited enforcement** – ICO could only issue fines up to £500,000
- **No mandatory breach reporting** – organisations could hide data breaches
- **Weaker individual rights** – no right to be forgotten or data portability
- **Implied consent** – consent was often assumed unless users opted out
- **Limited protection for children's data** – no specific requirements
- **Global data challenges** – law mainly applied in the UK despite international data flows



Legal compliance

- The **DPA 1998 required modernisation**, as it was introduced when the internet was still in its early stages.
- The **EU data protection rules on which it was based** were no longer suitable for:
 - Modern technologies (social networks, big data, cloud computing)
 - Globalisation of data processing



Therefore, a **new EU data protection regulation** was proposed in **2012**, introducing a **single regulation** with direct effect across all EU Member States after a transition period.

General Data Protection Regulation (GDPR)



General Data Protection Regulation (GDPR)

- A European Union law that sets rules for how personal data must be collected, used, and protected.
- Applied in the UK from 25 May 2018.

Official guidance is provided by the **Information Commissioner's Office (ICO)**.

[UK GDPR guidance and resources](#)

Re-form of EU Data Protection Law

- ✓ **Right to be forgotten:** Individuals can request the deletion of their personal data when it is no longer needed and there is no legitimate reason to retain it.
- ✓ **Explicit consent:** Consent for data processing must be clearly and actively given; it can no longer be assumed.
- ✓ **Access and data portability:** Individuals have easier access to their personal data and the right to transfer it between service providers.
- ✓ **Data breach notification:** Organisations must report serious data breaches without undue delay, and where possible within 72 hours.

Re-form of EU Data Protection Law

- ✓ **Single EU rulebook:** GDPR establishes one common set of data protection rules that apply across all EU countries.
- ✓ **One main data protection authority:** Companies deal with a single national data protection authority, usually in the country where their main establishment is located.
- ✓ **Greater transparency:** Organisations must clearly explain how personal data is handled, using information that is easy to understand, especially for children.
- ✓ **Local rights for individuals:** Individuals can refer cases to their own national data protection authority, even if their data is processed in another country.
- ✓ **Strong penalties for non-compliance:** Organisations that breach GDPR may face fines of up to 20 million euros or 4% of global annual turnover, whichever is higher.

Re-form of EU Data Protection Law

- ✓ **Applies beyond the EU:** GDPR applies to companies outside the EU if they offer goods or services in the EU or monitor the online behaviour of EU citizens.
- ✓ **Increased responsibility and accountability:** Organisations processing personal data must take greater responsibility through:
 - data protection risk assessments
 - appointment of data protection officers
 - applying **privacy by design** and **privacy by default**
- ✓ **Stronger enforcement:** National data protection authorities are strengthened to better enforce GDPR rules within their own countries.

Consent

- **High standard for consent:** GDPR requires clear and strong consent.
- **Positive opt-in:** Consent must be actively given. Pre-ticked boxes and default consent are not allowed.
- **Easy withdrawal:** People must be able to withdraw consent easily and be told how.
- **Change from previous rules:** Before GDPR, negative opt-in was often used for marketing.
- **Right to erasure:** Individuals can request deletion of their data when consent is withdrawn.



GDPR principles

Principle	Description
Lawfulness, Fairness, and Transparency	Data must be processed lawfully, fairly, and in a transparent manner for the data subject.
Purpose Limitation	Data should only be collected for a specific, explicit, and legitimate purpose and not used beyond that purpose.
Data Minimisation	Only collect necessary data – avoid excessive or irrelevant data collection.
Accuracy	Personal data must be accurate and kept up to date , with corrections made where necessary.
Storage Limitation	Data should not be kept longer than needed; must be deleted once no longer required.
Integrity and Confidentiality (Security)	Data must be protected against unauthorised access, loss, or breaches (e.g., encryption, access controls).
Accountability	Organisations must be able to demonstrate compliance with GDPR and take responsibility for data protection (e.g., appointing a Data Protection Officer).

Data protection officer (DPO)

- GDPR requires some organisations to appoint a **Data Protection Officer (DPO)**.
- Large organisations, such as those processing over 5,000 personal records per year or employing more than 250 staff, must appoint a DPO.
- The DPO is responsible for overseeing data protection and keeping personal data secure.



Question

How can personal data be obtained unlawfully?

But data privacy isn't only
important for consumers, it's
also important for businesses.

Data privacy breach

- **Definition (official)**

“a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorised disclosure of, or access to, personal data transmitted, stored or otherwise processed in connection with the provision of a public electronic communications service”.

- **Security responsibility (Principle 7):** Data controllers must have appropriate security measures in place to prevent personal data from being deliberately or accidentally compromised.
- **Enforcement and penalties:** Under UK GDPR, the ICO can impose fines of up to £17.5 million or 4% of global annual turnover for serious breaches.

[Personal data breaches: a guide](#)

[Report a data security breach \(PECR\)](#)



Information Commissioner's Office

Cymraeg

The ICO exists to empower you through information.

[Home](#) [For the public](#) [For organisations](#) [Make a complaint](#) [Action we've taken](#) [About the ICO](#)

[For organisations](#) / [Report a breach](#) / [Report a data security breach \(PECR\)](#)

Report a data security breach (PECR)

This form is for public electronic communications service providers to report a breach of security or send their completed monthly breach log to the ICO.

We will use the information you provide to record the breach and, if necessary, to investigate further. We may share the information with other law enforcement or regulatory bodies where necessary.

After you submit the form, we will email you a copy of your responses, along with a reference number for future correspondence. Please retain this email for your records.

You do not need to complete this form if by doing so you would breach an enactment, court order or certificate signed by a Minister of the Crown that allows you to withhold the information for national security purposes.

If you are subject to PECR and you experience a personal data breach, you should continue to report under PECR. There is no need to report under the DPA 2018 (UK GDPR), too.

[Start now →](#)

[Report a data breach \(GDPR\)](#)

Further reading

[Security breaches guidance](#)
For organisations

Issues: Data privacy policies, notices, statements - examples

- Amazon. Help and customer service. Privacy notice
<https://www.amazon.co.uk/gp/help/customer/display.html?nodeId=502584>
- Google. Privacy policy
<https://policies.google.com/privacy?hl=en-US>
- Information Commissioner's Office. Privacy notice
<https://ico.org.uk/global/privacy-notice/>
- Sainsbury's. Privacy policy
<https://www.about.sainsburys.co.uk/site-services/privacy-policy>
- NHS England. Privacy notice
<https://www.england.nhs.uk/contact-us/privacy-notice/>
- Netflix. Privacy statement
<https://help.netflix.com/legal/privacy>

Data privacy in other countries

- **United States:** Some states have their own privacy laws, such as the **California Consumer Privacy Act (CCPA)** and **Nevada privacy law**, which give individuals more control over their personal data.
- **Australia:** The **Privacy Act 1988** includes the **Australian Privacy Principles (APPs)**, covering transparency, data use, direct marketing, and security.
- **Health Insurance Portability and Accountability Act (HIPAA):**
A US law that protects personal health information and controls how medical data is used and shared.

Genetic Data Privacy Act (US)

- In 2022, the Wyoming Genetic Data Privacy Act was signed into law and came into force on **1 July 2022**.
- The Act requires businesses that collect genetic data to:
 - (1) **Provide clear and transparent information** about how genetic data is collected, used, and shared before collection, and
 - (2) **Obtain explicit consent** before collecting genetic data.It also strictly limits how genetic data can be shared and retained and does not apply to organisations.

Does GDPR Still Apply in the UK After Brexit?

Although GDPR originated as EU legislation, it was retained in UK law after the Brexit transition period and is now referred to as the **UK GDPR**. The UK GDPR operates alongside:

- the **Data Protection Act 2018 (DPA 2018)**, and
- the **Privacy and Electronic Communications Regulations (PECR)**.

Together, these form the UK's core framework for personal data protection.

Scope of the UK GDPR

- Applies to controllers and processors **based in the UK**.
- Also applies to organisations **outside the UK** if their processing:
 - offers goods or services to individuals in the UK, or
 - monitors the behaviour of individuals within the UK.

Data protection and digital information Bill (1)

- **More business-friendly approach** – Reduces compliance requirements, particularly for small and low-risk organisations.
- **Changes to data subject rights** – Updates how individuals can access, manage, and exercise control over their personal data.



The screenshot shows the UK Parliament website. At the top, the UK Parliament logo is visible. Below it, the heading 'Parliamentary Bills' is displayed. A red banner indicates the bill is in the 'HOUSE OF LORDS'. The breadcrumb trail reads: 'UK Parliament > Parliamentary Bills > Data Protection and Digital Information Bill'. A 'Bill feed' icon is also present. The main title of the bill is 'Data Protection and Digital Information Bill', followed by 'Government Bill'. Below this, it states 'Originated in the House of Commons, Sessions 2022-23, 2023-24' and 'Last updated: 23 September 2024 at 12:52'.

<https://ico.org.uk/about-the-ico/the-data-use-and-access-dua-bill/>
<https://bills.parliament.uk/bills/3430>

Data protection and digital information Bill (2)

- **New accountability role: Senior Responsible Individual (SRI)** – In some cases, replaces the requirement for a Data Protection Officer (DPO).
- **Easier international data transfers** – Introduces greater flexibility for sharing personal data across borders.
- **Stronger rules for AI and automated decision-making** – Updates data protection requirements to better reflect the use of AI and emerging technologies.



The screenshot shows the UK Parliament website. At the top, the UK Parliament logo is visible. Below it, the heading 'Parliamentary Bills' is displayed. A red banner indicates the bill is in the 'HOUSE OF LORDS'. The breadcrumb trail reads: 'UK Parliament > Parliamentary Bills > Data Protection and Digital Information Bill'. A 'Bill feed' icon is also present. The main title of the bill is 'Data Protection and Digital Information Bill', followed by 'Government Bill'. It states the bill was 'Originated in the House of Commons, Sessions 2022-23, 2023-24' and was 'Last updated: 23 September 2024 at 12:52'.

<https://ico.org.uk/about-the-ico/the-data-use-and-access-dua-bill/>
<https://bills.parliament.uk/bills/3430>

Data protection policy principles (1)

Australian law professor **Graham Greenleaf** identifies **ten** core data protection principles that are shared across four major international privacy frameworks:

- OECD Guidelines on the Protection of Privacy
- Council of Europe Convention (Convention 108)
- EU Data Protection Directive
- APEC Privacy Framework



Data protection policy principles (2)

1. **Collection** - limited, lawful and by fair means; with consent or knowledge
2. **Data quality** - relevant, accurate, up-to-date
3. **Purpose specification** - at time of collection
4. **Notice of purpose and rights** - at time of collection
5. **Uses limited (including disclosures)** - to purposes specified or compatible
6. **Security** - through reasonable safeguards
7. **Openness** - to personal data practices
8. **Access** - individual right of access
9. **Correction** - individual right of correction
10. **Accountable** - data controllers accountable for implementation

Sources – Data protection - General

Information Commissioner's Office. Guide to data protection

<https://ico.org.uk/for-organisations/guide-to-data-protection/>

Information Commissioner's Office. Guide to the General Data Protection Regulation (GDPR)

<https://ico.org.uk/for-organisations/guide-to-the-general-data-protection-regulation-gdpr>